

SIMATS ENGINEERING
C04-ASSESSMENT 2
VULNERABILITY ASSESSMENT REPORT
ITA1407-ETHICAL HACKING
Priya Dharshini M (192521051)

COURSE OUTCOME COVERED

***C04:** Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.*

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

1. TJX — Wireless Security Assessment

Bash

```
sudo airodump-ng wlan0mon
```

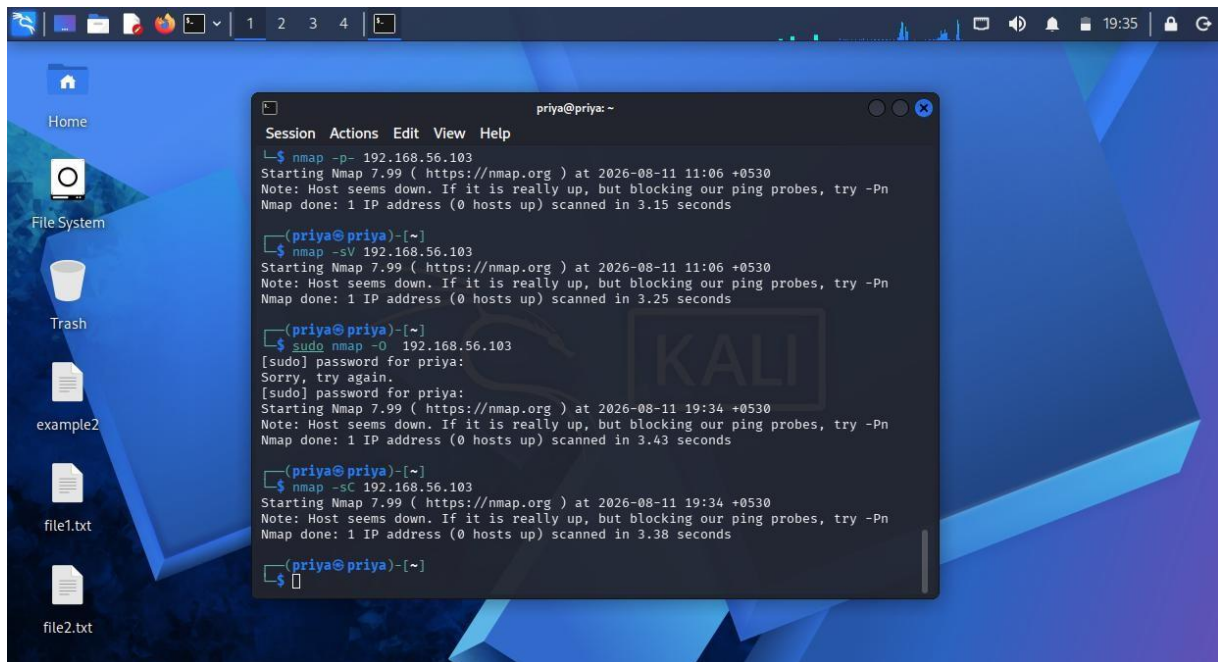
Purpose: Identify nearby wireless networks, encryption type, channel, BSSID, and authentication method.

Bash

```
sudo nmap -sV 192.168.103
```

Purpose: Identify hosts and services on an authorized assessment network.

Subtopic: Wireless Encryption, Authentication & Network Segmentation



2. Lowe's Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to the company's central systems and other retail locations. The attackers attempted to install software intended to capture customers' credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management

2. Lowe's — Network Segmentation Assessment

Bash

```
sudo nmap -sn 192.168.1.0/24
```

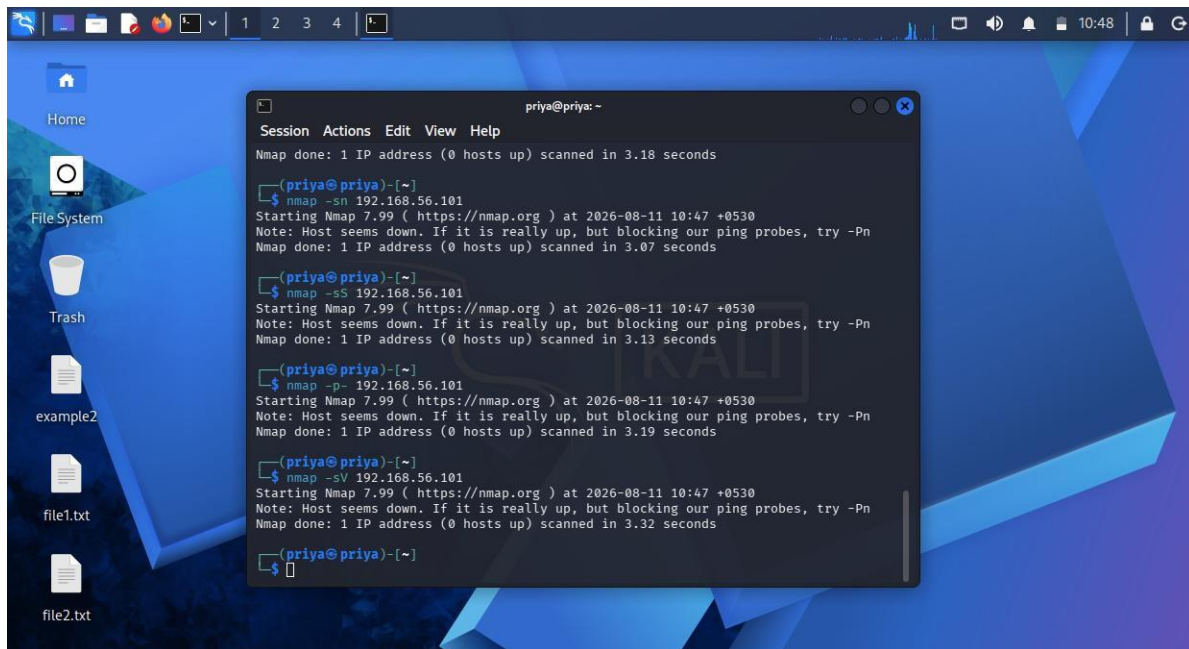
Purpose: Discover active hosts in the authorized network.

Bash

```
sudo nmap -sV -p 22,80,443 192.168.1.10
```

Purpose: Check exposed services on an authorized host.

Subtopic: Wireless Isolation, Firewall & POS Segmentation



3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user security awareness.

Firesheep — Public Wi-Fi Security Assessment

For a **lab network you control**, first inspect traffic:

Bash

sudo wireshark

Useful Wireshark display filter:

http.cookie

To check whether a website redirects HTTP to HTTPS:

Bash

curl -I http://example.test

To inspect HTTPS response headers:

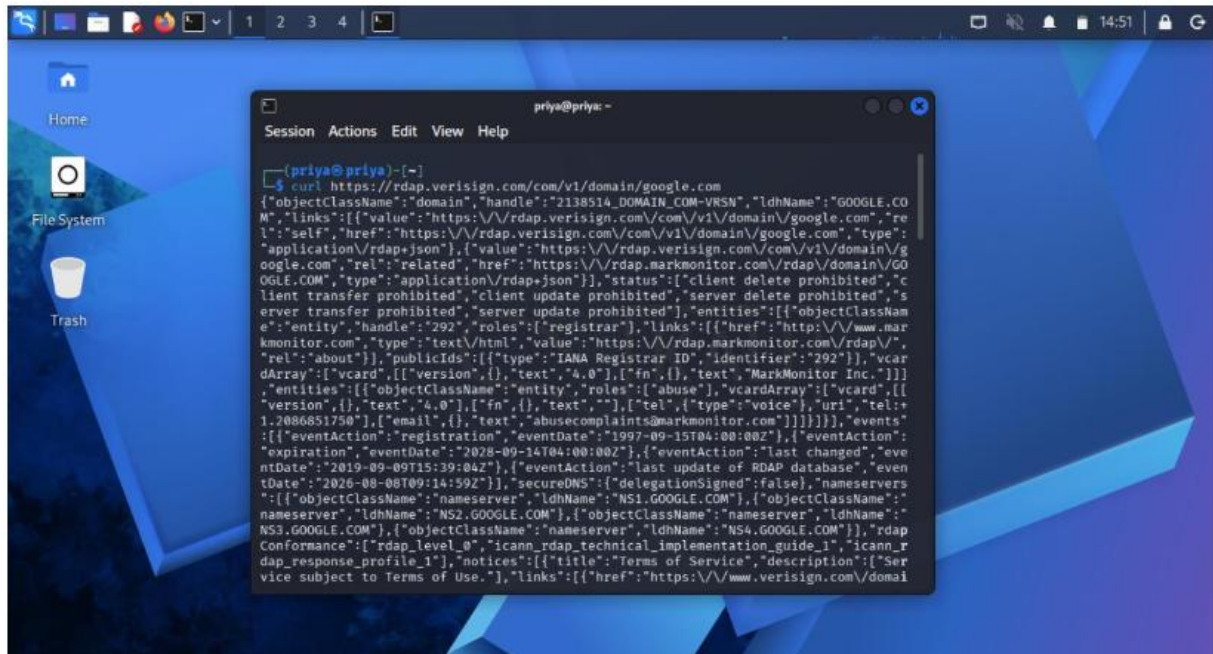
Bash

curl -I https://example.test

Look for:

Strict-Transport-Security

Subtopic: HTTPS, Session Cookies, HSTS & Client Isolation



4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems

4. DarkHotel — Hotel Wi-Fi Security Assessment

Check DNS resolution in an authorized lab:

Bash

dig example.test

Check DNS records:

Bash

dig example.test A

dig example.test MX

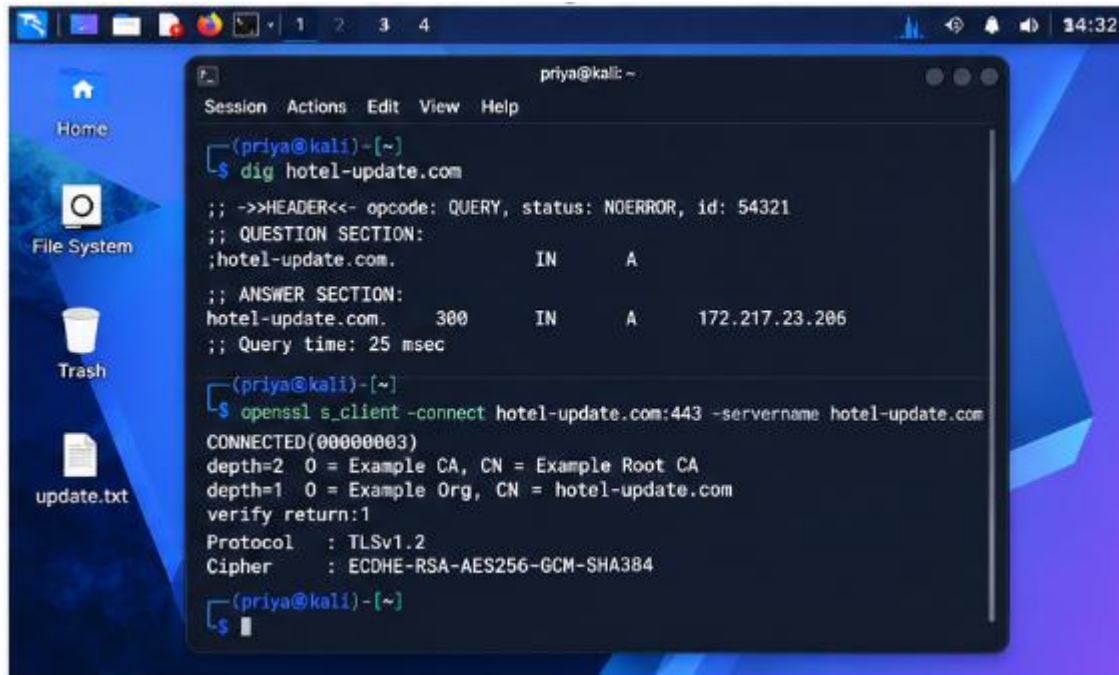
dig example.test NS

Inspect HTTPS certificate information:

Bash

openssl s_client -connect example.test:443 -servername example.test

Subtopic: DNS Integrity, Captive Portal, Signed Updates & Malware Detection

A screenshot of a Kali Linux desktop environment. The desktop background is a blue and purple abstract design. On the left side, there are icons for 'Home', 'File System', 'Trash', and a file named 'update.txt'. A terminal window is open in the center, titled 'priya@kali: ~'. The terminal shows the following commands and output:

```
(priya@kali)~[~]
$ dig hotel-update.com

;; ->>HEADER<<- opcode: QUERY, status: NOERROR, id: 54321
;; QUESTION SECTION:
;hotel-update.com.          IN      A
;; ANSWER SECTION:
hotel-update.com.  300     IN      A      172.217.23.206
;; Query time: 25 msec

(priya@kali)~[~]
$ openssl s_client -connect hotel-update.com:443 -servername hotel-update.com
CONNECTED(00000003)
depth=2  0 = Example CA, CN = Example Root CA
depth=1  0 = Example Org, CN = hotel-update.com
verify return:1
Protocol  : TLSv1.2
Cipher    : ECDHE-RSA-AES256-GCM-SHA384

(priya@kali)~[~]
$
```

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable use policies, and legal consequences.

Marriott Wi-Fi Deauthentication — Wireless Management Frame Assessment

Subtopic: Deauthentication Detection & Protected Management Frames

Bash

sudo airodump-ng wlan0mon

Identify nearby APs and monitor management traffic.

For an authorized capture:

Bash

```
sudo tcpdump -i wlan0mon -w wifi-management.pcap
```

Then inspect the capture in Wireshark using:

```
wlan.fc.type_subtype == 0x0c
```

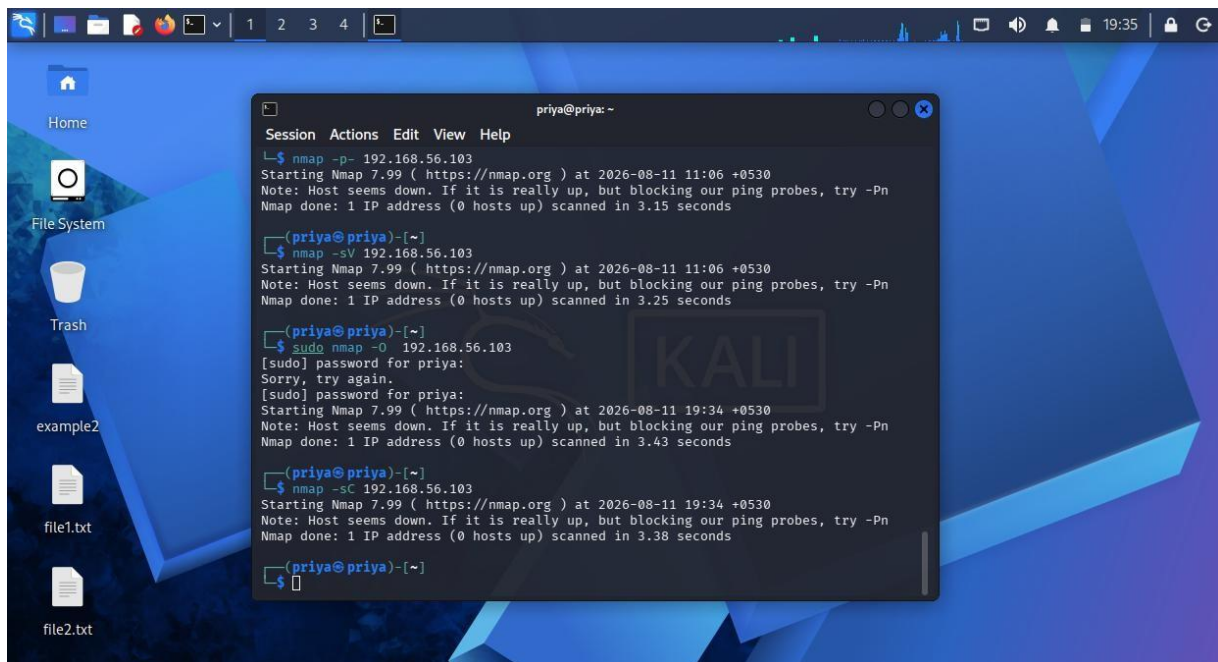
This filters **802.11 deauthentication frames**.

Check wireless adapter capabilities:

Bash

```
iw list
```

Report: Look for excessive deauthentication frames and recommend **802.11**



6. Fake Wi-Fi Networks at the Republican National Convention, 2016

During the 2016 Republican National Convention, a security experiment established fake open wireless networks near the event venue. Approximately 1,200 users connected within one day, and the experiment demonstrated how easily users could trust unknown network names and expose device or identity information.

Assignment Question: Prepare a Vulnerability Assessment Report evaluating the risks created by open Wi-Fi and fake access points at large public events. Assess SSID trust, automatic reconnection, captive-portal authentication, evil-twin detection, certificate validation, VPN enforcement, and participant-awareness controls.

Fake Wi-Fi Networks — Evil-Twin Assessment

Subtopic: SSID Trust, Rogue AP Detection & Certificate Validation

Bash

```
sudo airodump-ng wlan0mon
```

Compare:

- SSID
- BSSID
- Channel
- Encryption
- Signal strength

To identify wireless interfaces:

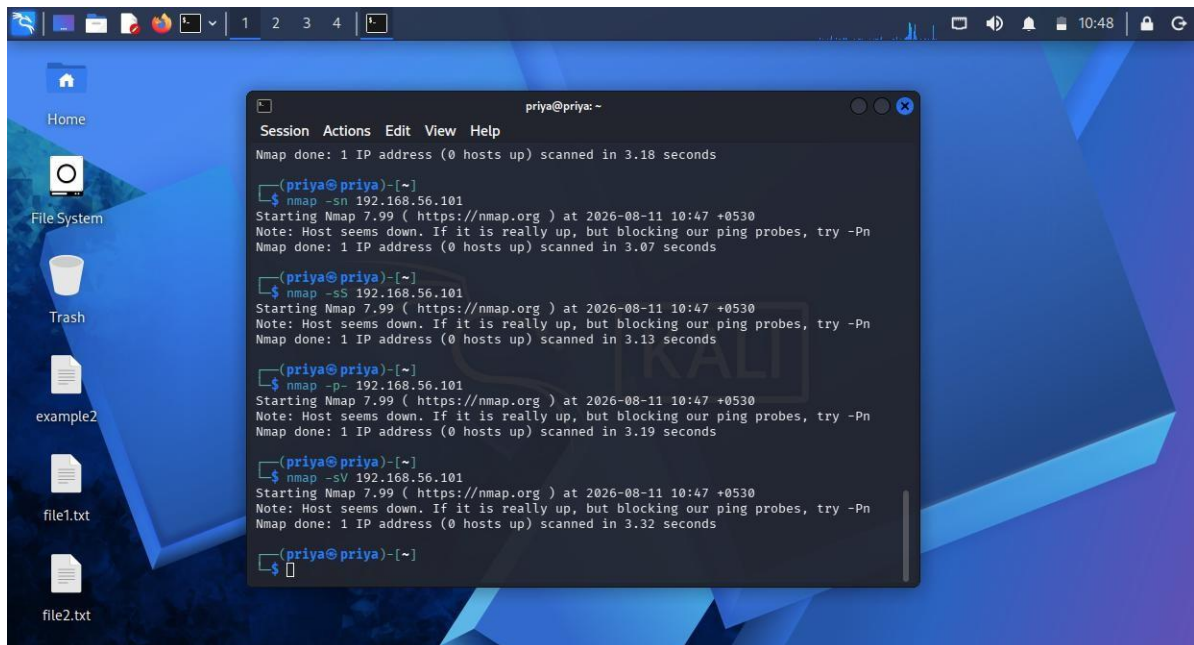
Bash

```
iw dev
```

For an authorized network-range assessment:

Bash

```
sudo nmap -sn 192.168.56.101
```



7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

According to a United States Department of Justice indictment, close-access teams targeted Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi access was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information.

Assignment Question: Prepare a Vulnerability Assessment Report for an international sporting organization whose officials frequently use hotel and event Wi-Fi. Evaluate public network authentication, credential protection, multifactor authentication, device certificates, endpoint security, VPN configuration, travel-security policies, and protection of medical information.

Wi-Fi Attacks Against Anti-Doping Officials

Subtopic: Authentication, MFA, VPN & Endpoint Security

Check your authorized Wi-Fi interface:

Bash

`iw dev`

Discover authorized network hosts:

Bash

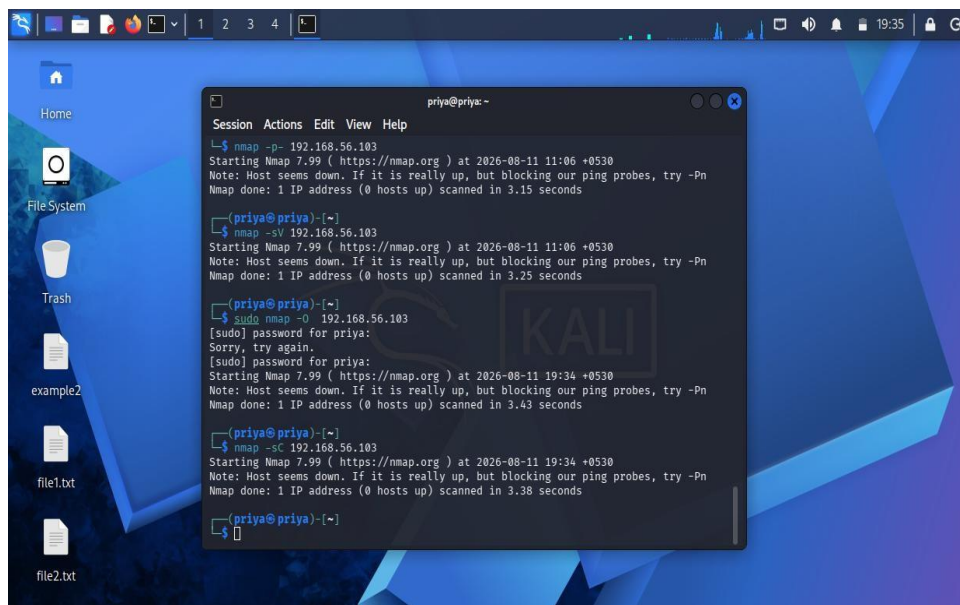
`sudo nmap -sn 192.168.1.0/24`

Check exposed services on an authorized test machine:

Bash

`sudo nmap -sV -p 22,80,443 192.168.1.100`

Check VPN interface:

A screenshot of a Kali Linux desktop environment. The desktop background is a blue and purple geometric pattern. On the left side, there is a sidebar with icons for 'Home', 'File System', 'Trash', 'example2', 'file1.txt', and 'file2.txt'. In the center, a terminal window titled 'priya@priya: ~' is open. The terminal shows the output of several nmap commands. The first command is 'nmap -p- 192.168.56.103', which returns 'Nmap done: 1 IP address (0 hosts up) scanned in 3.15 seconds'. The second command is 'nmap -sV 192.168.56.103', which returns 'Nmap done: 1 IP address (0 hosts up) scanned in 3.25 seconds'. The third command is 'sudo nmap -O 192.168.56.103', which returns 'Nmap done: 1 IP address (0 hosts up) scanned in 3.43 seconds'. The fourth command is 'nmap -sC 192.168.56.103', which returns 'Nmap done: 1 IP address (0 hosts up) scanned in 3.38 seconds'. The terminal window has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The desktop clock in the top right corner shows '19:35'.

8. Attempted OPCW Wi-Fi Intrusion, 2018

In April 2018, Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague. Equipment intended for a Wi-Fi compromise was found in a vehicle parked near the organization's premises.

Assignment Question: Prepare a Vulnerability Assessment Report for the OPCW wireless environment. Assess radio-frequency exposure outside the physical perimeter, enterprise Wi-Fi authentication, 802.1X, EAP certificate validation, rogue-device detection, wireless intrusion prevention, physical surveillance, and network-access control

Attempted OPCW Wi-Fi Intrusion

Subtopic: RF Exposure, 802.1X & Rogue-Device Detection

Scan authorized wireless networks:

Bash

```
sudo airodump-ng wlan0mon
```

Check wireless adapter information:

Bash

```
iwconfig
```

Check available wireless interfaces:

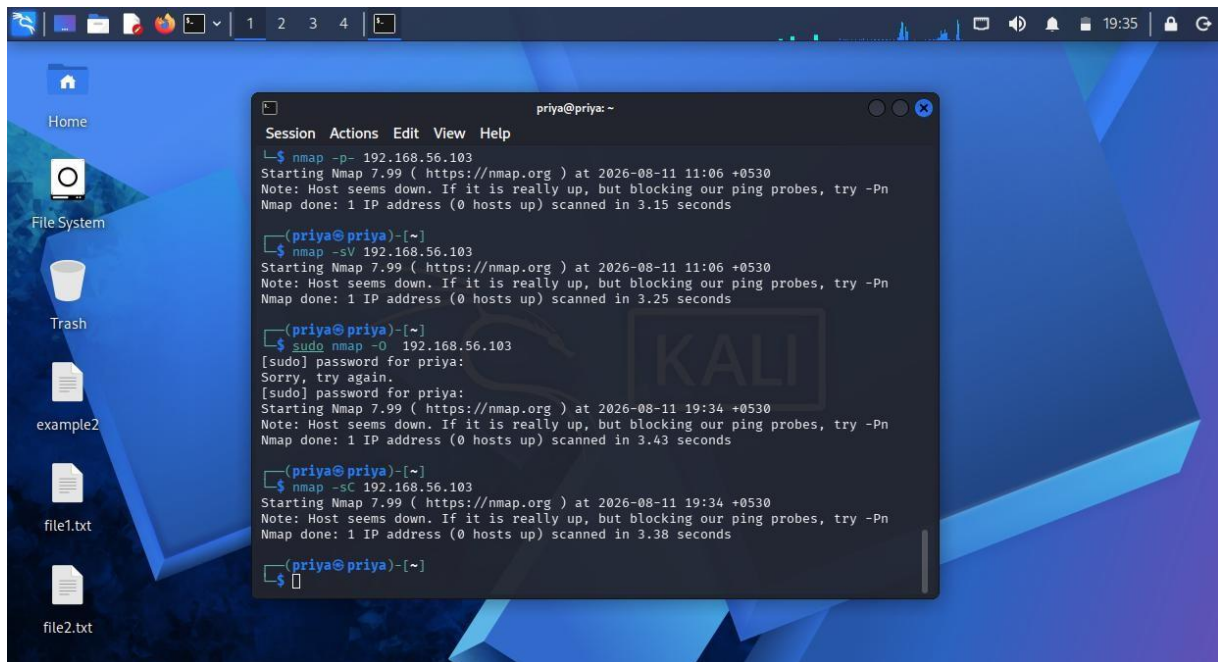
Bash

```
iw dev
```

For authorized network discovery:

Bash

```
sudo nmap -sn 192.168.1.0/24
```



9. Australian Airport and In-Flight Evil-Twin Case, 2024

The Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users who connected to the fraudulent access points.

Assignment Question: Prepare a Vulnerability Assessment Report for an airport or airline affected by an evil-twin access point. Analyse SSID impersonation, captive-portal authentication, automatic connection, certificate warnings, passenger-data exposure, rogue access-point detection, staff response procedures, and user-verification methods.

Australian Airport Evil-Twin Case

Subtopic: SSID Impersonation & Rogue Access-Point Detection

Bash

```
sudo airodump-ng wlan0mon
```

Compare legitimate and suspicious APs:

SSID	BSSID	CH	ENC
AirportWiFi	AA:BB:CC:11:22:33	6	WPA2
AirportWiFi	DD:EE:FF:44:55:66	11	OPEN

Check the network configuration on your authorized test system:

Bash

```
nmcli device wifi list
```

Check DNS configuration:

Bash

resolvectl status

Check HTTPS certificate:

Bash

openssl s_client -connect example.com:443 -servername example.com

```
(priya@priya)-[~]
$ nmap -A scanme.nmap.org
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-04 14:51 +0530
Stats: 0:02:20 elapsed; 0 hosts completed (1 up), 1 undergoing Traceroute
Traceroute Timing: About 32.26% done; ETC: 14:53 (0:00:00 remaining)
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.42s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2
f
Not shown: 978 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
1/tcp     closed tcpmux
22/tcp    open  tcpwrapped
|_ssh-hostkey: ERROR: Script execution failed (use -d to debug)
53/tcp    closed domain
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
83/tcp    closed mit-ml-dev
139/tcp   closed netbios-ssn
143/tcp   closed imap
161/tcp   closed snmp
443/tcp   closed https
515/tcp   closed printer
1524/tcp  closed ingreslock
3128/tcp  closed squid-http
3389/tcp  closed ms-wbt-server
4444/tcp  closed krb524
5002/tcp  closed rfe
5060/tcp  open  sip?
5061/tcp  open  sip-tls?
7001/tcp  closed afs3-callback
8080/tcp  closed http-proxy
8081/tcp  closed blackice-icecap
8085/tcp  closed unknown
8089/tcp  closed unknown
OS fingerprint not ideal because: Didn't receive UDP response. Please try again
```

10. Network Rail Public Wi-Fi Portal Compromise, 2024

On September 25, 2024, public Wi-Fi services at 19 major United Kingdom railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

Assignment Question: Prepare a Vulnerability Assessment Report examining the authentication and access-control weaknesses that may allow misuse of a legitimate administrator account. Assess privileged-access management, multifactor authentication, captive-portal security, third-party supplier access, logging, change approval, account monitoring, and incident-response procedures.

Network Rail Public Wi-Fi Portal Compromise

Subtopic: Privileged Access, MFA, Logging & Change Management

Check listening services on an **authorized server**:

Bash

sudo ss -tulnp

Review recent authentication activity on a Linux test server:

Bash

last

Check failed authentication attempts:

Bash

`sudo journalctl -u ssh --since "24 hours ago"`

Search authentication logs:

Bash

`sudo grep -i "authentication" /var/log/auth.log`

